

OBJETIVO AUDITADO: PINOESPACESVERTS.ONLINE

URL Completa: https://pinoespacesverts.online/

68/100

POSTURA ACEPTABLE

0

VULN. CRÍTICAS

4

PROBLEMAS / MEJORAS

6

CONTROLES OK

1. RESUMEN EJECUTIVO DE SEGURIDAD

Durante la auditoría pasiva no intrusiva realizada sobre el activo pinoespacesverts.online, el motor JOM SENTINEL evaluó la configuración de cabeceras HTTP, transporte TLS, políticas de seguridad de contenido (CSP), protección contra Clickjacking (X-Frame-Options), banderas de cookies y exposición de rutas o activos sensibles frente a las 106 clases del Atlas de Ataque y Defensa.

Se identificaron 0 vulnerabilidades críticas y 4 fallas de configuración que requieren atención inmediata para prevenir ataques de intermediario, secuestro de clics, o robo de sesiones. La solución técnica de blindaje JOM Studio puede desplegarse en un plazo de 24 a 48 horas sin interrumpir la operativa del sitio ni alterar la experiencia de navegación de los usuarios.

2. MAPA DE HALLAZGOS DESTACADOS (ATLAS JOM STUDIO)

ID ATLAS	TÍTULO DE LA VULNERABILIDAD	SEVERIDAD	ESTADO
CL-03	CSP débil (unsafe-inline / eval)	PROBLEMA	Acción Req.
SC-04	Scripts de terceros sin SRI (1)	PROBLEMA	Acción Req.
CL-01	Formulario de login sin token CSRF visible	PROBLEMA	Acción Req.
CL-01	Formulario de login sin token CSRF visible	PROBLEMA	Acción Req.

CL-03 — CSP débil (unsafe-inline / eval)

- Diagnóstico / Señal: La política permite scripts inline o eval(), lo que reduce drásticamente la protección contra XSS.
- **Vector de Explotación:** La falta de CSP permite la ejecución de scripts no autorizados ante un fallo XSS.
- **Solución Defensiva JOM Studio:** nonce o hash por request

Código / Directiva recomendada: `Header always set X-Content-Type-Options "nosniff"`

SC-04 — Scripts de terceros sin SRI (1)

- Diagnóstico / Señal: Scripts cargados desde orígenes externos sin atributo integrity. Si el CDN sufre compromiso, se ej...
- **Vector de Explotación:** Un atacante aprovecha esta ausencia para interceptar tráfico o inyectar contenido.
- **Solución Defensiva JOM Studio:** SRI para scripts/styles de terceros

Código / Directiva recomendada: `Header always set X-Content-Type-Options "nosniff"`

CL-01 — Formulario de login sin token CSRF visible

- Diagnóstico / Señal: No se detectó token anti-CSRF en el formulario de login. Validar protección SameSite o cabeceras p...
- **Vector de Explotación:** Un atacante aprovecha esta ausencia para interceptar tráfico o inyectar contenido.
- **Solución Defensiva JOM Studio:** SameSite=Lax/Strict

Código / Directiva recomendada: `Header always set X-Content-Type-Options "nosniff"`

CL-01 — Formulario de login sin token CSRF visible

- Diagnóstico / Señal: No se detectó token anti-CSRF en el formulario de login. Validar protección SameSite o cabeceras p...
- **Vector de Explotación:** Un atacante aprovecha esta ausencia para interceptar tráfico o inyectar contenido.
- **Solución Defensiva JOM Studio:** SameSite=Lax/Strict

Código / Directiva recomendada: `Header always set X-Content-Type-Options "nosniff"`

PLAN DE REMEDIACIÓN Y BLINDAJE INTEGRAL JOM STUDIO

1. Configuración de Cabeceras Maestras (HSTS, CSP strict, XFO, nosniff, Referrer-Policy).
2. Hardening de Sesión y Cookies (Flags Secure, HttpOnly, SameSite=Lax en producción).
3. Integridad de Recursos (SRI subresource integrity en todos los scripts de terceros).
4. Revalidación Defensiva con Burp Suite Professional y emisión de Certificado Seguro JOM.

Tiempo de Ejecución: 24 a 48 Horas hábiles · Web: jomstudiovzla.github.io/Jomstudiopage/index.html